

Bulletins-Cyber

L'Agonie de NTLM Comprendre les Attaques de Relais et l'Avenir de l'Active Directory (2021-2026)

1. Le Contexte : La persistance de NTLM au sein des infrastructures modernes

L'Active Directory (AD) constitue la pierre angulaire de la gestion des identités et des accès dans un réseau d'entreprise. Son rôle central est de vérifier et de valider de manière stricte chaque demande d'authentification sur le domaine.

Dans ce cadre, deux protocoles de vérification coexistent, bien qu'ils offrent des niveaux de sécurité très inégaux :

- **Kerberos** : Il s'agit du standard de sécurité actuel. C'est un protocole d'authentification réseau moderne et robuste, qui s'appuie sur un système de tickets chiffrés pour garantir l'intégrité et la confidentialité des échanges.
- **NTLM (New Technology LAN Manager)** : C'est un protocole hérité (*legacy*) conçu dans les années 1990. Son architecture, basée sur un mécanisme de défi/réponse, est aujourd'hui obsolète et dépourvue des protections cryptographiques modernes.

Malgré les préconisations répétées de Microsoft en faveur d'un basculement exclusif vers Kerberos, NTLM demeure massivement présent dans les environnements d'entreprise. Cette situation s'explique principalement par la **dette technique** : les organisations sont souvent contraintes de maintenir NTLM actif pour assurer la rétrocompatibilité avec des applications vieillissantes, des équipements industriels ou des systèmes tiers non mis à jour.

Les acteurs de la menace ont parfaitement identifié cette faille structurelle. Profitant de la faiblesse inhérente de NTLM, ils déploient des stratégies offensives ciblant spécifiquement ces environnements de transition, la technique la plus critique et la plus exploitée étant l'attaque par **Relais NTLM**.

2. Comment fonctionne l'attaque : Le combo "PetitPotam" + Relais

L'attaque se déroule en deux grandes étapes. C'est ce qu'on appelle une attaque de type "Man-in-the-Middle".

Étape A : La Coercition (Forcer la main avec PetitPotam)

L'outil **PetitPotam** est comme un faux appel téléphonique urgent.

L'attaquant envoie une requête malveillante au serveur le plus important du réseau (le Contrôleur de Domaine). Il lui fait croire qu'il *doit* se connecter d'urgence à une machine distante pour lire un fichier (via le protocole MS-EFSRPC). Le serveur, obéissant, tente de s'authentifier en envoyant sa vieille carte d'identité (NTLM) à la machine de l'attaquant.

Étape B : Le Relais (Usurpation d'identité)

L'attaquant ne connaît pas le mot de passe du serveur, mais il a intercepté sa tentative de connexion NTLM. Il va simplement prendre cette connexion "au vol" et la **relayer** (la faire suivre) vers un autre service critique, comme le serveur de certificats de l'entreprise (AD CS).

1. Le serveur de certificats croit qu'il parle au Contrôleur de Domaine légitime.
2. Il délivre un "pass VIP" (un certificat informatique) à l'attaquant.
3. L'attaquant utilise ce certificat pour prendre le contrôle total du réseau (devenir Administrateur du Domaine).

3. L'Évolution de la Menace (2025-2026)

Les pirates ne s'arrêtent pas là. Même si des correctifs ont été publiés, de nouvelles failles continuent d'apparaître, prouvant que NTLM est structurellement cassé :

- **Faible LDAP (CVE-2025-54918)** : Découverte début 2026, elle permet aux pirates de modifier les paquets réseau pour désactiver les signatures de sécurité et forcer une connexion, contournant les défenses qu'on pensait solides.

- **Réflexion NTLM** : L'attaquant arrive même à renvoyer l'authentification d'un serveur contre ce même serveur pour le pirater de l'intérieur.

4. Comment se défendre ? (Les recommandations de l'ANSSI)

Pour bloquer ces attaques, l'ANSSI impose une stratégie de "défense en profondeur".

Actions Techniques Immédiates

- **Activer l'EPA (Extended Protection for Authentication)** : C'est une sécurité supplémentaire qui lie l'authentification à une session cryptée précise, rendant le relais impossible.
- **Bloquer le trafic NTLM sortant** : Interdire aux serveurs importants d'initier des connexions NTLM vers l'extérieur.
- **Filtres RPC** : Mettre des "pare-feux internes" pour bloquer les appels malveillants comme ceux de PetitPotam.

Que faut-il surveiller dans les logs ?

Les événements clés à connaître (Event IDs) :

ID d'Événement	Ce que cela signifie	Pourquoi c'est suspect ?
8001	Audit de restriction NTLM	Un serveur a essayé d'utiliser NTLM au lieu de Kerberos.
4001	Blocage NTLM	Le système a bloqué une tentative suspecte (bonne nouvelle !).
4624	Connexion réussie (anormale)	Connexion NTLM avec un nom de machine "vide" = signature typique de PetitPotam.

5. Perspectives 2026 : La Fin du Jeu pour NTLM

Nous sommes en 2026, et c'est une année charnière. Microsoft a décidé de débrancher la prise.

- **Désactivation par défaut** : Les nouvelles versions de Windows Server en 2026 n'ont plus NTLM activé par défaut (*Secure by Default*).
 - **Nouveaux Protocoles** : Microsoft déploie **IAKerb** et le **Local KDC**, qui permettent d'utiliser Kerberos partout, même pour des machines isolées, éliminant ainsi toute excuse pour garder NTLM.
 - **L'Impact Légal (NIS2)** : En France, avec l'accélération de la directive européenne NIS2 en 2026, si une entreprise stratégique se fait pirater parce qu'elle n'a pas désactivé NTLM (ignorant les règles de l'ANSSI), elle risque de lourdes amendes pour négligence.
-

En résumé

NTLM est obsolète. Tant qu'il sera là, les pirates utiliseront des outils comme PetitPotam pour voler les clés du royaume. La seule vraie solution n'est pas de colmater les brèches une à une, mais d'éradiquer totalement NTLM au profit de Kerberos.